

MARCO INTEGRATIVO GQM + PRAGMATIC

Metodología Unificada para Indicadores CRM 2024-2025

Versión: 2.0 | **Fecha:** Enero 2026 | **Clasificación:** Público

INTRODUCCIÓN EJECUTIVA

Este documento integra dos metodologías complementarias:

1. GQM (Goal-Question-Metric) — Proporciona trazabilidad jerárquica desde objetivos estratégicos nacionales → preguntas operacionales → métricas técnicas
2. PRAGMATIC (9 criterios) — Evalúa viabilidad práctica de cada métrica en términos predictivos, accionables, rentables, etc.

GQM (Goal-Question-Metric) — Proporciona **trazabilidad jerárquica** desde objetivos estratégicos nacionales → preguntas operacionales → métricas técnicas

PRAGMATIC (9 criterios) — Evalúa **viabilidad práctica** de cada métrica en términos predictivos, accionables, rentables, etc.

Propósito: Garantizar que cada indicador CRM sea:

- ✓ Estratéigicamente alineado (GQM)
- ✓ Operacionalmente viable (PRAGMATIC)
- ✓ Normativamente fundado (GDPR/DORA/NIS2)

PARTE 1: METODOLOGÍA GQM APLICADA A CRM

1.1 — Estructura Jerárquica GQM

NIVEL 1: GOAL (Objetivo Estratégico Nacional)

- └─ Mejorar resiliencia cibernética de España
- └─ Reducir brecha madurez vs líderes EU
- └─ Cumplir GDPR/DORA/NIS2

↓

NIVEL 2: QUESTION (Pregunta Operacional)

- └─ ¿Cuál es la postura actual de gobernanza?
- └─ ¿Qué brecha existe vs target?
- └─ ¿Qué inversión es necesaria?

↓

NIVEL 3: METRIC (Métrica Técnica Cuantificable)

- └─ IGM Score (0-4.0)
- └─ Domain Gap (actual - target)
- └─ ALE Reduction (€/año)

1.2 — Modelo GQM Completo para CRM

GOAL G1: Establecer Gobernanza Estratégica

Nivel	Contenido	Ejemplo
Goal	Garantizar que la ciberseguridad sea responsabilidad de junta directiva	Objetivo nacional NIS2
Question	¿Existe RAS documentado aprobado junta? ¿CISO reporta CEO?	NIST Govern.RM-2
Metric	(1) % CISO report línea directa CEO; (2) RAS versión + fecha aprobación	KPI gobernanza

GOAL G2: Cuantificar Riesgos en Términos Monetarios

Nivel	Contenido	Ejemplo
Goal	Transformar riesgos abstractos a ALE para decisiones presupuesto	FAIR framework adoption
Question	¿Top 5 riesgos cuantificados? ¿ROI decisiones control?	CFO accionable
Metric	(1) ALE Top 5 Risks (€); (2) ROI % por control; (3) % inversiones ROI-justified	Financial KPIs

GOAL G3: Modelar Amenazas a Nivel Operacional

Nivel	Contenido	Ejemplo
Goal	Transformar threat modeling abstracto en attack scenarios concretos	PASTA framework
Question	¿100% apps críticas con threat model? ¿Attack trees con PoC?	Coverage
Metric	(1) % apps con PASTA (0-100%); (2) Attack tree maturity (0-4); (3) PoC success rate	Operational KPIs

GOAL G4: Detectar Incidentes Rápidamente

Nivel	Contenido	Ejemplo
Goal	Reducir tiempo detección incidentes; target <30 min (benchmark)	SOC effectiveness
Question	¿Cuál es MTTD actual? ¿Trending mejorando?	Performance trend
Metric	(1) MTTD median (minutos); (2) MTTD 90th percentile; (3) Month-over-month delta	Speed KPI

GOAL G5: Responder Incidentes en Ventana Aceptable

Nivel	Contenido	Ejemplo
Goal	Contener incidentes en <4 horas (DORA target)	Financial resilience
Question	¿MTTR por severidad? ¿Cumple SLA?	Compliance
Metric	(1) MTTR critical (horas); (2) % incidentes <SLA; (3) Severity distribution	Resilience KPI

GOAL G6: Gestionar Vulnerabilidades con Rigor

Nivel	Contenido	Ejemplo
Goal	Parchear vulnerabilidades críticas <7 días	Breach prevention
Question	¿Scanning continuo? ¿SLA cumplido?	Coverage + speed
Metric	(1) Scanning frequency; (2) % críticos parcheados <7d; (3) Mean patch time	Hygiene KPI

GOAL G7: Gestionar Riesgo Supply Chain

Nivel	Contenido	Ejemplo
Goal	Auditar 100% proveedores críticos anualmente	Third-party risk
Question	¿Cuántos terceros auditados? ¿SBOM mantenido?	Coverage
Metric	(1) % proveedores críticos auditados; (2) Audit findings remediated %; (3) SBOM freshness	Vendor KPI

GOAL G8: Mejorar Comportamiento Seguro Empleados

Nivel	Contenido	Ejemplo
Goal	Reducir phishing click rate; target <5%	Human risk
Question	¿Click rate actual? ¿Training efectivo?	Behavior change
Metric	(1) Phishing click rate %; (2) Report rate %; (3) Training completion %	Awareness KPI

GOAL G9: Cumplir Regulaciones (GDPR/DORA/NIS2)

Nivel	Contenido	Ejemplo
Goal	Alcanzar 100% compliance cada regulación	Legal risk reduction
Question	¿Gaps GDPR/DORA/NIS2? ¿Sanciones potenciales?	Audit readiness
Metric	(1) GDPR % compliance; (2) DORA % compliance; (3) NIS2 % compliance; (4) Potential fine (€)	Compliance KPI

GOAL G10: Automatizar Compliance

Nivel	Contenido	Ejemplo
Goal	80%+ políticas ejecutadas vía código (Policy-as-Code)	Operational efficiency
Question	¿% políticas automatizadas? ¿Drift detection?	Scale
Metric	(1) % Policy-as-Code adoption; (2) Drift incidents/mes; (3) Deployment time (min)	Automation KPI

PARTE 2: CRITERIOS PRAGMATIC (9 DIMENSIONES)

2.1 — Definición de Cada Criterio

Criterio	Definición	Pregunta Clave
P — Predictivo	¿Predice comportamiento futuro/incidentes? ¿Correlaciona con outcomes?	¿Nos advierte antes de problema?
R — Relevante	¿Importa a stakeholders (CEO, CFO, regulador)? ¿Alineado objetivos?	¿Importa al negocio?
A — Accionable	¿Podemos actuar basados en dato? ¿Trigger para decisión/acción?	¿Qué hacemos cuando sube/baja?
G — Genuino	¿Es métricamente válido? ¿No es gaming/manipulable?	¿Mide lo que pretende medir?
M — Significativo	¿Impacto material si mejora? ¿Correlaciona con riesgo real?	¿Importa el cambio?
A — Preciso	¿Operacionalmente definido? ¿Replicable/auditable?	¿Podemos reproducir medición?
T — Oportuno	¿Disponible frecuencia relevante? ¿Reportable en tiempo útil?	¿Tenemos dato cuando lo necesitamos?
I — Independiente	¿No depende de otras métricas? ¿Minimiza redundancia?	¿Es métrica standalone?
C — Rentable	¿Bajo costo colección? ¿Esfuerzo justificado ROI?	¿Vale la pena recolectarlo?

2.2 — Escala de Calificación PRAGMATIC

Para cada métrica, calificar 0-5 por cada criterio:

- 0 = No cumple; no viable
- 1 = Débil cumplimiento; issues graves
- 2 = Parcial cumplimiento; mejoras necesarias
- 3 = Cumplimiento aceptable; estándar
- 4 = Fuerte cumplimiento; recomendado
- 5 = Óptimo cumplimiento; excellence

Score PRAGMATIC Final = Promedio 9 criterios

- 9/45 = 0.0-1.0 → No recomendado ❌
- 9/45 = 1.1-2.5 → Débil; revisar ⚠️
- 9/45 = 2.6-3.5 → Aceptable ✓
- 9/45 = 3.6-4.5 → Fuerte ✓✓
- 9/45 = 4.6-5.0 → Óptimo ✓✓✓

PARTE 3: MATRIZ INTEGRADA GQM ↔ PRAGMATIC

3.1 — Ejemplo Completo: Métrica MTTD (Mean Time To Detect)

GQM Mapping

GOAL G4: Detectar incidentes rápidamente

QUESTION: ¿Cuál es MTTD actual? ¿Trending mejorando?

METRIC: MTTD median (minutos)

- Definición operacional: Timestamp incidente detectado - Timestamp inicio (log evidence)
- Fuente datos: SIEM event logs + analyst manual detection
- Frecuencia: Daily (rolling 30-day window)
- Target: <30 minutos (industry benchmark)
- Responsable: SOC Manager

PRAGMATIC Evaluation

Criterio	Puntuación	Justificación
Predictivo	4/5	MTTD bajo predice baja breach impact; correlación documentada IBM DBIR
Relevante	5/5	DORA Art 19 exige "incident detection"; crítico para junta
Accionable	4/5	Si MTTD >1h → escalar SOC; trigger bien definido
Genuino	5/5	Timestamp objective; no gaming posible
Significativo	5/5	Cada 10 min reduction = €500K+ breach cost savings
Preciso	5/5	Definición operacional clara; auditable
Oportuno	4/5	Disponible daily; reportable real-time
Independiente	4/5	Algo dependencia MTTR (ambos incidente lifecycle); acceptable
Rentable	4/5	Extraído SIEM existente; bajo costo adicional
PRAGMATIC Score	4.4/5	✓✓ Fuerte; altamente recomendado

3.2 — Tabla Síntesis: 15 Indicadores CRM Core

Indicador	GQM Goal	Definición	Target	PRAGMATIC
IGM Score	G1-G10	Índice Global Madurez (0-4)	3.5 (2026)	4.3
MTTD	G4	Detección (minutos)	<30	4.4
MTTR	G5	Respuesta crítico (horas)	<4	4.3
Patch % Crítico <7d	G6	Remediación vuln (%)	95%	4.2
Phishing Click Rate	G8	Comportamiento (%)	<5%	4.1
RAS Documentado	G1	Gobernanza (yes/no)	100%	4.5
ALE Top 5 Risks	G2	Cuantificación (€)	Establecido	4.2
PASTA Coverage	G3	Threat modeling (%)	100% críticos	3.8
Vendor Audit %	G7	Supply chain (%)	100%	4.0
Policy-as-Code %	G10	Automatización (%)	80%	4.1
GDPR Compliance %	G9	Regulatorio (%)	95%	4.4
DORA Compliance %	G9	Regulatorio (%)	100%	4.4
NIS2 Readiness %	G9	Regulatorio (%)	90% (pre-trans)	4.3
Alert False Positive %	G4	SIEM quality (%)	<5%	3.9
Training Completion %	G8	Awareness (%)	95%	4.2

PARTE 4: CASOS DE USO GQM + PRAGMATIC

4.1 — Justificación de Métrica a Junta

Escenario: CFO cuestiona por qué invertir €50K en SIEM

Respuesta GQM + PRAGMATIC:

GQM Alignment:

Goal: Detectar incidentes rápidamente (G4)

Question: ¿MTTD actual vs target?

Metric: MTTD = 48h actual → <30 min post-SIEM

Impacto Financiero:

Current ALE breach: €5M

MTTD reduction impact: -60% = €3M anual

SIEM cost: €50K

ROI: 60:1 | Payback: 2 semanas

PRAGMATIC Validation:

- Predictivo ✓: MTTD bajo = breach cost bajo (IBM data)
- Accionable ✓: IF MTTD >1h THEN escalate
- Rentable ✓: Auto-extract SIEM; <€5K setup
- Target realistic ✓: Industry best = 30 min; achievable

4.2 — Validar Métrica No-Funcional

Escenario: Equipo propone métrica "Satisfacción CISO con seguridad postura" (1-10 scale)

Evaluación PRAGMATIC:

Criterio	Score	Problema
Predictivo	0/5	✗ No predice incidentes; subjetivo
Genuino	1/5	✗ Altamente gaming; bias cognitivo
Preciso	0/5	✗ "Satisfacción" indefinible; no auditable
Conclusión	⚠	RECHAZADA; proponer alternativa objetiva

PARTE 5: IMPLEMENTACIÓN PASO-A-PASO

Paso 1: Mapeo GQM (Semana 1)

- Listar 10 goals estratégicos CRM
- Refinar cada goal en 3-5 questions
- Para cada question, especificar 1-3 metrics concretas
- Validar trazabilidad goal ↔ question ↔ metric

Paso 2: Evaluación PRAGMATIC (Semana 2)

- Para cada métrica, calificar 9 criterios (0-5)
- Documentar justificación cada scoring
- Calcular PRAGMATIC score promedio
- Identificar métricas débiles (<3.0); rechazar o mejorar

Paso 3: Validación (Semana 3)

- ☐ Consenso stakeholders cada métrica
- ☐ Definición operacional final
- ☐ Responsable + frecuencia colección
- ☐ Target + SLA

Paso 4: Implementación (Semana 4+)

- ☐ Setup colección datos
- ☐ Automatizar reportes
- ☐ Baseline histórico
- ☐ Monitor trending mensual

CONCLUSIÓN

GQM proporciona **rigor estratégico** (trazabilidad goal → metric).

PRAGMATIC proporciona **viabilidad operacional** (asegurar métrica es útil, accionable, rentable).

Combinadas: Indicadores CRM que son simultáneamente:

- ✓ Estratégicamente alineados (junta aprueba)
- ✓ Técnicamente válidos (CISO confía)
- ✓ Operacionalmente viables (implementables)
- ✓ Financieramente justificados (CFO approves)

Fin Marco Integrativo GQM + PRAGMATIC